Тестовое задание:

формирование фида индикаторов компрометации

Отчёт

Выполнил: Кустов Владислав

9 ноября 2026 г.

1. Постановка задачи

Целью работы являлась разработка алгоритма и программного обеспечения для формирования фида индикаторов компрометации (IoC) в формате JSONL. В качестве источников данных использовались MalwareBazaar, APT ETDA и VirusTotal. Выходной набор данных должен содержать 100 записей (по одной на каждый образец) со следующими полями: md5, sha256, malware_class, malware_family, av_detects, threat_level.

Базовым набором данных выступала выборка из 100 последних хешей, загруженных на платформу MalwareBazaar, откуда извлекались значения хеш-сумм и сигнатуры семейств вредоносного программного обеспечения (ВПО). Класс ВПО определялся посредством сопоставления сигнатуры с базой APT ETDA, а массив обнаружений формировался на основе отчета VirusTotal. Выбор уровня угрозы (LOW, MEDIUM, HIGH) и обоснование логики оценки являлись зоной ответственности исполнителя.

Ввиду отсутствия в исходном техническом задании явных спецификаций по нормализации наименований (например, расхождения вида QuasarRAT и Quasar RAT), обработке пустых сигнатур и алгоритмам поведения при отсутствии семейства в ETDA, соответствующие механизмы нормализации и обработки исключений были спроектированы в ходе реализации.

2. Архитектура и алгоритм работы решения

Программа main.py структурно разделен на четыре логических модуля: импорт данных, корреляция, аналитическая обработка и экспорт. Алгоритм выполнения представлен в таблице 1.

Таблица 1 — Шаги выполнения

Этап	Описание
Подготовка	Чтение ключей аутентификации VT_API_KEY и MB_AUTH_KEY из конфигурационного файла secrets.env. В исходном коде ключи отсутствуют.
Сбор данных MalwareBazaar	Выполнение запроса get_recent с селектором 100. Сохранение ответа в локальный кэш data/raw/mb/recent_100.json.
Сбор данных VirusTotal	Отправка запросов к эндпоинту /files/{sha256}. Извлечение полей last_analysis_results и popular_threat_classification. Реализован механизм кэширования и ограничение частоты запросов (пауза 16 секунд).
Сбор данных APT ETDA	Загрузка двух MISP-кластеров в формате JSON: инструменты (getmisp.cgi?o=t) и APT-группировки (getmisp.cgi?o=g). Данные сохраняются в data/raw/etda.
Индексация ETDA	Нормализация названия инструментов и синонимы. Получается соответствие «нормализованное имя → типы + APT-группы».
Определение класса ВПО	Определение по трем источникам: APT ETDA, хвост названия семейства, категории VirusTotal.
Оценка уровня угрозы	Распределение по трем группам риска, повышение уровня при наличии связей с APT-группировками, обработка исключений (отсутствие класса).
Экспорт данных	Формирование файла output/malware_feed.jsonl (одна запись на строку). Сводка дублируется в консоль.

Для обхода ограничений при установке TLS-соединения с серверами virustotal.com с российских IP-адресов (ошибка WinError 10054) реализована поддержка проксирования через переменную окружения HTTPS_PROXY. Доступ к MalwareBazaar и ETDA осуществляется напрямую. Взаимодействие с API сопровождается механизмом повторных попыток (retries) для обработки тайм-аутов и ошибок HTTP 429.

3. Алгоритм определения класса ВПО (malware_class)

Классификация объектов строго ограничена файлом ТЗ из 57 классов, предоставленным в исходных материалах. Определение класса выполняется последовательно по трем источникам до первого успешного совпадения.

Источник 1: База APT ETDA

База представляет собой реестр APT-группировок и применяемых ими инструментов (2198 карточек инструментов, 514 групп). Идентификация осуществляется по полю meta.type и связанным APT-группам.

Сопоставление базируется на нормализованном имени: приведение к нижнему регистру, удаление спецсимволов и суффиксов (RAT, Stealer, Loader и др.). Во избежание ложных срабатываний (например, распознавание слова «pure» как отдельного семейства) установлена минимальная длина строки для индексации — 5 символов. Найденные типы транслируются в целевые классы согласно таблице маппинга (Таблица 2). Если класс установлен через ETDA, дальнейший поиск прекращается.

Источник 2: хвост названия

В случае отсутствия семейства в базе ETDA анализируется суффикс наименования. Применяется справочник из 15 суффиксов (например, наличие «Stealer» классифицируется как Trojan-PSW, «Locker» — Trojan-Ransom). Данная эвристика отличается высокой производительностью и позволила классифицировать 43 записи в текущей выборке.

Источник 3: вердикт VirusTotal

Резервным источником выступают категории из поля popular_threat_classification.popular_threat_category отчета VirusTotal. При отсутствии данных о сигнатуре в ответе MalwareBazaar наименование семейства извлекается из popular_threat_name. Низкий процент пересечения с ETDA (5 семейств на 40 уникальных сигнатур) объясняется профилем базы ETDA, ориентированной исключительно на целевые атаки, а не на массовое ВПО.

Таблица 2 — Типы ETDA и категории VirusTotal в классах справочника (сокращённо)

Тип в источнике	Источник	Класс
backdoor, remote command, botnet, control panel	ETDA	Backdoor
info stealer, credential stealer	ETDA	Trojan-PSW
keylogger, exfiltration	ETDA	Trojan-Spy
banking trojan, POS, ATM, SWIFT	ETDA	Trojan-Banker
ransomware, big game hunting	ETDA	Trojan-Ransom
downloader	ETDA	Trojan-Downloader
loader, dropper	ETDA	Trojan-Dropper
tunneling	ETDA	Trojan-Proxy
ddos	ETDA	Trojan-DDoS
worm	ETDA	Worm
rootkit	ETDA	Rootkit
reconnaissance, vulnerability scanner, poisoning	ETDA	HackTool
0-day	ETDA	Exploit
wiper, miner, ICS	ETDA	Trojan
trojan, spyware, stealer, rat, virus, adware	VT	Trojan, Trojan-Spy, Trojan-PSW, Backdoor, Virus, Adware

4. Оценка уровня угрозы (threat_level)

57 классов ВПО распределены по трем категориям риска на основании их деструктивного потенциала (Таблица 3). Итоговый уровень угрозы объекта соответствует максимальному уровню среди всех присвоенных ему классов.

Таблица 3 — Три группы классов

Группа	Классы	Обоснование
HIGH (9 классов)	Backdoor, Rootkit, Bootkit, Trojan-Ransom, Trojan-Banker, Trojan-PSW, Trojan-Spy, Trojan-IM, Trojan-GameThief	ВПО, обеспечивающее полный контроль над скомпрометированной системой, осуществляющее шифрование данных или хищение критичной информации и финансовых средств.
MEDIUM (25 классов)	Trojan, Trojan-Dropper, Trojan-Downloader, Trojan-Proxy, Trojan-DDoS, Worm, Virus, Exploit, HackTool, DoS, Phishing и родственные	Векторы доставки полезной нагрузки, средства распространения, инструментарий атакующих и сетевые аномалии.
LOW (23 класса)	Adware, RiskTool, RemoteAdmin, Server-*, Client-*, Spam, Hoax, PSWTool, Spoofer и подобные	Нежелательное программное обеспечение, рекламные модули и легитимные административные утилиты двойного назначения.

Оценка уровня угрозы на базе весовых коэффициентов была отклонена ввиду необходимости ручной калибровки и субъективности оценок; выбранный подход с

жесткой категоризацией обеспечивает прозрачность и повторяемость результата. Дополнительные эвристики:

- Наличие доказанной связи семейства с APT-группировкой (по данным ETDA) повышает уровень угрозы на одну ступень ввиду повышенной опасности целевых атак.
- В случае отсутствия идентифицированного класса уровень угрозы оценивается на основе наличия обнаружений (av_detects): при их наличии устанавливается MEDIUM, при отсутствии — LOW.

5. Результаты разметки

Результаты обработки тестовой выборки представлены в таблицах 4 и 5.

Таблица 4 — Статистика разметки

Показатель	**Значение**
Записей в фиде	100
С классом / без класса	98 / 2
Уровни (LOW / MEDIUM / HIGH)	2 / 31 / 67
Источник класса: (ETDA / хвост / VT / нет)	7 / 43 / 48 / 2
С сигнатурой / без сигнатуры	61 / 39
Разных сигнатур / найдено в ETDA	40 / 5
Записей с APT-связью	7
Детектов у записи: минимум / максимум / в среднем	0 / 40 / 27

Таблица 5 — Частотность выявленных классов

Класс	**Записей**
Trojan	47
Trojan-PSW	27
Trojan-Spy	25
Backdoor	18
Trojan-Ransom	11
Trojan-Dropper	8
Virus	4
Adware	3
Worm	3
HackTool	2
Trojan-Downloader	2

Преобладание уровня угрозы HIGH (67%) коррелирует со спецификой источника (MalwareBazaar), где доминируют стилеры и RAT-трояны (Trojan-PSW, Trojan-Spy и Backdoor составляют 70 упоминаний). Класс Adware зафиксирован всего 3 раза, всегда в связке с классом Trojan.

Записи без сигнатуры (39 шт.) преимущественно обрабатывались через механизм VirusTotal (37 шт.). Две записи (c1d65303… и 53e9b53a…) с пустой сигнатурой и отсутствием обнаружений на VirusTotal закономерно получили уровень LOW ввиду невозможности классификации. Распределение уровней угрозы в зависимости от источника класса (Таблица 6) демонстрирует, что эвристика по суффиксам генерирует преимущественно уровень HIGH (40 из 43), тогда как категоризация VirusTotal обеспечивает баланс между MEDIUM (28 из 48) и HIGH (20 из 48).

6. Что не получилось и что улучшил бы

Эффективность ETDA для массового потока ВПО оказалась низкой (7 совпадений из 100). Оптимальным вектором развития является изменение алгоритма поиска: первичное определение семейства через VirusTotal с последующим поиском выявленного семейства в ETDA.

Использование общих категорий VirusTotal для записей без сигнатуры снижает точность классификации конкретного семейства.

Отнесение классов Trojan-Downloader и HackTool к уровню MEDIUM может быть пересмотрено в контексте анализа цепочек заражения (kill chain) в целевых атаках.

Анализ суффиксов подвержен ошибкам на генерических сигнатурах (например, genericml, disco). Требуется внедрение белых/черных списков или ручная верификация частотных исключений.

Лимиты бесплатной версии VirusTotal (4 запроса в минуту) существенно увеличивают время первичной инициализации фида (~30 минут). Учет количества антивирусных обнаружений при расчете уровня угрозы в текущей реализации минимизирован для сохранения детерминированности логики алгоритма.

В целом, поставленная задача выполнена: структура выходного фида соответствует требованиям, алгоритм классификации и оценки риска прозрачен и проверяем.

Приложение А. Пять строк фида

Ниже представлены пять записей из сгенерированного файла output/malware_feed.jsonl (массив av_detects усечен для удобства восприятия).

{"md5": "4a815e2ef6c93ddc2c82c15184ca1e3a", "sha256": "ec138352c4726fa3b6706b30bf4692252f818108c8066e8518920dd9823a34bb", "malware_class": ["Trojan-Ransom", "Backdoor", "Worm"], "malware_family": ["WannaCry"], "av_detects": ["W32.Malware.C82E9508", "Exploit.CVE-2017-0147", "Ransom-WannaCry!4A815E2EF6C9", "CVE20170147.Trojan.Exploit.DDS"], "threat_level": "HIGH"}
{"md5": "457013a94eefd116aeb5dd4762c3c44e", "sha256": "bfc5d48c6d67111d90eeeb6c69d1236f09c6bdfea94163e2af680e16a012a0ff", "malware_class": ["Backdoor", "Trojan-Spy", "Trojan-PSW"], "malware_family": ["QuasarRAT"], "av_detects": ["Malware.Heuristic.2041", "win/malicious_confidence_90% (D)", "ti!BFC5D48C6D67", "Static AI - Suspicious PE"], "threat_level": "HIGH"}
{"md5": "c794a375acde0bd7d8668ba587b49587", "sha256": "fba02b35c4c5ba90c275cdc38f752ffe1390641464cfd00acf29c31e0a52e6e9", "malware_class": ["Trojan", "Trojan-Dropper"], "malware_family": ["Mirai"], "av_detects": ["Linux.Trojan.Gafgyt", "Unix.Dropper.Mirai-7136288-0", "Suspicious.Linux.Save.a", "Linux.Mirai"], "threat_level": "MEDIUM"}
{"md5": "b0dec3bbbf80b095cf626c6e10d9e208", "sha256": "da5f7780e90052ed2d9c810548434ffa84b4231910fd3bfcd4a9f13043e00750", "malware_class": ["Backdoor"], "malware_family": ["LarpestanRAT"], "av_detects": ["ML.Attribute.HighConfidence", "malicious (high confidence)", "Win64/Spy.Agent.YT trojan", "HEUR:Trojan-PSW.Win32.Agent.gen"], "threat_level": "HIGH"}
{"md5": "fccdfea383a8d06fd152c2ffbd185dd0", "sha256": "c1d653030b4bde65d3e07e4d0b0979e17be56df1436cdd15528630f27808050d", "malware_class": [], "malware_family": [], "av_detects": [], "threat_level": "LOW"}

Приложение Б. Инструкция по развертыванию

Предварительные требования: Python 3.10+, сторонние зависимости отсутствуют.

Настройка окружения (файл secrets.env располагается в корневой директории и игнорируется VCS):

```
Bashcp secrets.env.example secrets.env # Внести ключи VT_API_KEY, MB_AUTH_KEY (опционально HTTPS_PROXY)

python main.py
```

Структура проекта подразумевает сохранение ответов API в локальный кэш. Удаление директории data/raw инициирует повторный сбор данных из сетевых источников при следующем запуске. Результаты формируются в директории output/.